

GESTORA — Qué falta por hacer

Resumen ejecutivo · 3 de septiembre de 2026 · rama master en f65950c

Este documento resume lo que queda pendiente tras la revisión de esta sesión. Se corrigieron **11 defectos** en tres fases de auditoría (entrada por URL, Server Actions y subida de archivos), todos validados y publicados. Lo que sigue está ordenado por urgencia: primero lo que caduca o se encarece con el tiempo, después el trabajo de producto.

1. Bloqueadores inmediatos

Todo lo que estaba commiteado ya está publicado en origin. Lo que sigue abajo **existe solo en este computador** o pierde valor si se posterga.

Pendiente	Detalle	Riesgo si se posterga
23 archivos sin commitear	15 en el worktree <code>.codex/.../workera</code> (nómina, importación de facturas) y 8 en <code>workera-mt3b-r2</code> (asistencia, motor de reglas, sync). Es trabajo en curso de Codex.	Se pierde al cambiar de PC
Dos conflictos ya identificados	<code>nomina-de-pago/export/[batchId]/route.ts</code> y <code>src/lib/sync/scheduler.ts</code> : ambos modificados sin commitear y también cambiados en master.	Crece con cada commit
Rebase de Codex	<code>codex/mt3b-attendance-tenant</code> está 10 commits por detrás de master; <code>codex/ex4-expense-ocr</code> , 1.	Barato ahora, caro luego
Rama sin mergear	<code>claude/fix-orphan-document-upload</code> (1 commit, validado): evita el documento huérfano en Storage.	El arreglo no protege a nadie

Nota: no commiteé los 23 archivos a propósito. Es código que no escribí y que no puedo validar; podría estar a medio editar. Requiere la decisión de quien lo está trabajando.

2. Gate de segunda empresa (MT-3B a MT-3D)

Es el bloqueo estructural del producto. Hoy **solo ARCOTEX puede operar el dominio laboral**. MT-3B cerró el primer recorte — `employees` y `employee_groups` — y quedó validado con 890 pruebas pgTAP. Falta el resto.

Dominios laborales todavía sin `company_id`

asistencia · horas extra · ausencias · documentos · períodos · nómina · licencias médicas · colaciones · feriados · catálogos

Los seis requisitos que exige la documentación antes de activar un segundo cliente

- Incorporar y rellenar `company_id` en todas las tablas laborales.
- Reemplazar claves y FKs globales por equivalentes tenant-aware, con relaciones compuestas.
- Aplicar RLS por empresa a todo el dominio, con mínimo privilegio para funciones y `service_role`.
- Propagar el tenant a consultas, comandos, sincronización, exports, Storage y jobs.
- Probar aislamiento negativo entre dos empresas en lectura, escritura, relaciones, RPCs, archivos y procesos asíncronos.
- Recién entonces cambiar `workspace_enabled` a `true`.

La recomendación de la propia documentación es avanzar **por dominio, en migraciones pequeñas**, con backfill explícito y pruebas de cruce entre empresas antes de pasar al siguiente.

3. Despliegue y operación

Pendiente	Estado real hoy
EX-4 (OCR de rendiciones)	Completo y validado en local, pero nunca desplegado a staging . Azure deshabilitado (<code>EXPENSE_OCR_ENABLED=false</code>). Ningún resultado fue probado contra la API real.
Invitaciones	Se registran, pero registrar no equivale a enviar. Falta conectar envío y aceptación.
MFA	Pendiente para cuentas privilegiadas.
Observabilidad de plataforma	Faltan métricas agregadas y auditoría sanitizada, sin convertir el control plane en acceso silencioso a PII.
Entorno local	Docker/Supabase inestable: el contenedor de base perdió el esquema dos veces durante la sesión. Se recupera con <code>npmx supabase db reset --local</code> .

4. Riesgos conocidos y aceptados

No son defectos abiertos por descuido: son límites que se decidieron conscientemente y conviene que queden por escrito.

Riesgo	Por qué sigue abierto
Documento huérfano por error transitorio	La subida escribe en Storage antes que la metadata. Se cerró el disparador alcanzable (tipo inválido, id no-UUID), pero un fallo transitorio de base tras una subida correcta sigue dejando el archivo. Cerrarlo pide invertir el orden o abrir una policy de DELETE que rompería la inmutabilidad deliberada del bucket.
Plantilla de asistencia de RRHH	Se descartó: rellenaba bloques existentes y no sabía agregar filas, así que no podía representar a nadie contratado después. El Excel se genera siempre desde cero. Revertible con <code>git revert 0edb274</code> .
Pipeline de sync de Workera	Única superficie de entrada sin auditar . Es la que no viene de un usuario, donde un cambio de formato del proveedor tiene efectos silenciosos sobre asistencia.

5. Lo que ya NO falta

Verificado en esta sesión, para que nadie lo rehaga:

- **11 defectos corregidos** en validación de entrada por URL, Server Actions y subida de archivos.
- **Autorización de Server Actions:** las 13 superficies con "use server" autorizan por su cuenta.
- **Concurrencia del versionado:** las 13 tablas con `is_current` tienen índice único parcial. Dos decisiones simultáneas no pueden dejar dos filas vigentes.
- **Rutas de autenticación:** sin redirect abierto; el prefijo `origin` lo impide.
- **Privacidad de documentos:** RLS con `can_manage_employee` en tabla y en Storage; rutas sanitizadas, sin traversal posible.

Estado de validación al cierre: `tsc` limpio · lint en 0 · 736 pruebas TypeScript · `next build` correcto · 890 pruebas pgTAP en 48 archivos.